SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA1412**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis
Questions

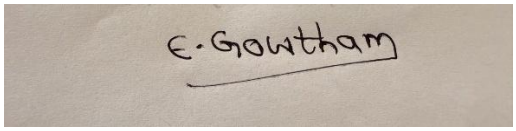
1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(**20 Mark).**

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Code of Conduct:

I Enamala Gowtham /192311190 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: 

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

QUESTION 1: NMAP NETWORK SCAN REPORT ANALYSIS

1. Introduction

Network scanning is an important activity in ethical hacking and cybersecurity. It helps security analysts identify active systems, open ports, running services, operating systems, and possible vulnerabilities. Nmap (Network Mapper) is a popular tool used to perform network scanning and gather information about target systems.

In this case, a security analyst scanned the target system with IP address 192.168.1.10 using Nmap. The report identified three open ports: HTTP (80), SSH (22), and MySQL (3306). The report also provided information about the operating system and service versions.

These findings help administrators understand which services are accessible and whether they are configured securely. However, an open port does not automatically mean that a system is vulnerable. The actual risk depends on the software version, configuration, network exposure, authentication, and security controls.

2. Analysis of the Nmap Report

The scan identified three important services running on the target system.

A. HTTP – Port 80

HTTP stands for Hypertext Transfer Protocol. It is used to transfer web pages and other information between web servers and web browsers.

Port 80 is the default port used by HTTP. When this port is open, it usually indicates that a web server is accepting connections.

Security risks:

1. HTTP traffic is not encrypted by default.
2. Sensitive information may be exposed if transmitted without HTTPS.
3. Outdated web server software may contain known vulnerabilities.
4. Poorly configured web applications may expose confidential information.
5. Weak authentication and session management may allow unauthorized access.
6. Improper input validation may lead to web application attacks.
7. Unnecessary files, directories, or administrative pages may be exposed.

Possible attack scenarios:

An attacker may inspect publicly accessible web pages and identify the software used by the server. If the website contains a security weakness, the attacker may attempt to exploit it. If confidential information is transmitted over an unencrypted connection, someone able to monitor the network may be able to observe that information.

Security measures:

- Enable HTTPS using a valid TLS certificate.
- Keep the web server and application updated.

- Remove unnecessary files and default pages.
- Disable directory listing when it is not required.
- Use secure authentication and session management.
- Validate user input and use secure coding practices.
- Apply web application firewall rules where appropriate.
- Regularly conduct authorized security testing.

B. SSH – Port 22

SSH stands for Secure Shell. It provides an encrypted connection for remote administration of computers and servers. Port 22 is the default port used by SSH.

SSH is useful because it protects communication between the client and server. However, incorrect configuration or weak authentication can create security risks.

Security risks:

1. Weak passwords may be guessed by attackers.
2. Reused or stolen credentials may allow unauthorized login.
3. Outdated SSH software may contain security vulnerabilities.
4. Unrestricted remote access increases exposure.
5. Excessive administrator privileges can increase the impact of a compromise.
6. Poor private-key protection may allow unauthorized access.
7. Repeated login attempts may indicate password-guessing activity.

Possible attack scenarios:

An attacker may attempt unauthorized access using stolen credentials or exploit a known vulnerability in an outdated SSH implementation. If an account has administrator privileges, unauthorized access may affect important system files, applications, or data.

Security measures:

- Use strong, unique authentication credentials.
- Prefer SSH key-based authentication where appropriate.
- Enable multifactor authentication where supported.
- Disable direct root login.
- Restrict SSH access to approved IP addresses or a management network.
- Remove unused user accounts.
- Keep SSH software updated.
- Monitor authentication logs and repeated login failures.
- Protect private keys from unauthorized access.

C. MySQL – Port 3306

MySQL is a relational database management system used to store and manage structured information. It is commonly used by websites and business applications.

Port 3306 is the default port for MySQL. If this port is open, it may indicate that a database service is accepting network connections.

Security risks:

1. Unauthorized users may attempt to access the database.
2. Weak database passwords may allow unauthorized login.
3. Excessive permissions may allow users to access unnecessary information.
4. Outdated database software may contain known vulnerabilities.
5. Poor database configuration may expose sensitive records.
6. Insecure application queries may create SQL injection risks.
7. Unprotected backups may expose confidential information.

Possible attack scenarios:

An attacker may attempt to access an unnecessarily exposed database using stolen credentials or exploit a known software weakness. If access is obtained, the attacker may read, modify, or delete records depending on the privileges of the compromised account.

For example, if a database contains customer information, unauthorized access may expose names, email addresses, or other sensitive business data.

Security measures:

- Restrict port 3306 using firewall rules.
- Allow database connections only from approved application servers and administrators.
- Use strong, unique database passwords.
- Remove unnecessary accounts and permissions.
- Apply the principle of least privilege.
- Update MySQL to a supported and secure version.
- Encrypt database connections when appropriate.
- Protect database backups.
- Enable database logging and monitor suspicious access.

3. Importance of Operating System and Service Versions

Nmap can identify operating systems and service versions when sufficient information is available. This information helps security analysts determine whether systems may be running outdated or unsupported software.

Older software may contain known vulnerabilities that attackers could attempt to exploit. However, identifying a version alone does not prove that a vulnerability exists because security patches, backported fixes, and configuration differences may affect the result.

Administrators should verify the installed versions and patch levels, review trusted vendor security advisories, and prioritize important vulnerabilities.

4. Overall Security Risks

The Nmap report indicates that the target system provides web access, remote administration, and database services.

Service	Port	Main security risk
HTTP	80	Unencrypted traffic and web application weaknesses
SSH	22	Unauthorized remote access
MySQL	3306	Database exposure and unauthorized data access

The MySQL service may require particular attention if it is accessible from untrusted networks because databases often contain important business information. SSH should also be restricted to authorized administrators.

5. Recommended Security Measures

The organization should implement the following measures:

1. Port management: Close unnecessary ports and disable unused services.
2. Firewall configuration: Permit only required connections from approved sources.
3. Software updates: Install security patches for the operating system and applications.
4. Strong authentication: Use secure credentials and multifactor authentication where appropriate.
5. Access control: Give each user only the permissions required for their responsibilities.
6. Encryption: Protect sensitive communication using HTTPS, SSH, and secure database connections.
7. Security monitoring: Review logs for suspicious activity and unauthorized access attempts.
8. Backup management: Maintain protected and regularly tested backups.
9. Vulnerability assessment: Conduct authorized assessments regularly.
10. Verification: Repeat the relevant security tests after implementing corrections.

6. Conclusion

The Nmap scan provides useful information about the target system's open ports, services, operating system, and software versions. HTTP may expose web applications to security weaknesses, SSH may be targeted through compromised credentials, and MySQL may expose sensitive database information if improperly configured.

The organization should secure each service through access restrictions, strong authentication, regular patching, encryption, and continuous monitoring. After applying the recommended measures, the security analyst should conduct an authorized re-scan to verify that the identified risks have been reduced.

QUESTION 2: GOPHISH PHISHING AWARENESS CAMPAIGN ANALYSIS

1. Introduction

Phishing is a social-engineering attack in which an attacker attempts to deceive people into clicking malicious links, providing confidential information, or downloading harmful attachments. Phishing messages may appear to come from trusted organizations, colleagues, banks, or service providers.

GoPhish is a tool that can be used to conduct authorized phishing-awareness simulations. These simulations help organizations evaluate employee responses and improve their security awareness.

In this case, ABC Technologies Pvt. Ltd. conducted a phishing-awareness campaign using GoPhish. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several employees downloaded a malicious attachment.

These findings indicate that the organization should improve its employee awareness programs and review its technical security controls.

2. Analysis of the Campaign Results

A. Employees Clicking the Phishing Link – 40%

The report states that 40% of employees clicked the phishing link. This suggests that a significant proportion of recipients interacted with the simulated message.

Possible reasons include:

- Employees did not carefully check the sender's email address.
- The message appeared to come from a trusted organization.
- The subject line created urgency or curiosity.
- Employees did not inspect the destination of the link.
- Employees were unfamiliar with common phishing indicators.
- Employees acted quickly without verifying the request.

Clicking a link does not automatically mean that a computer has been compromised. The risk depends on the destination, the user's subsequent actions, and the security controls in place.

Recommended measures:

Employees should be trained to inspect suspicious messages, verify unexpected requests, and avoid clicking unfamiliar links. Email filtering and link-protection tools should also be used to reduce exposure to malicious websites.

B. Employees Entering Login Credentials – 20%

The report states that 20% of employees entered their login credentials.

This is a serious concern because login credentials may provide access to email accounts, business applications, cloud services, and internal systems.

Security weaknesses demonstrated:

1. Employees may not recognize fake login pages.

2. Some users may trust messages that imitate legitimate services.
3. Employees may not verify the website address before entering credentials.
4. Users may not understand the risks associated with credential theft.
5. The organization may need stronger identity-security controls.

Possible consequences:

- Unauthorized access to employee accounts.
- Exposure of confidential company information.
- Impersonation of employees.
- Fraudulent emails sent from compromised accounts.
- Unauthorized access to business applications.
- Further phishing attempts against colleagues or customers.

Recommended measures:

Employees should access important services through official applications or trusted bookmarks instead of unexpected email links. The organization should enforce multifactor authentication, monitor suspicious sign-ins, and establish a quick process for reporting suspected credential exposure.

C. Employees Downloading a Malicious Attachment

The report also indicates that several employees downloaded a malicious attachment.

Email attachments can be used to deliver harmful files or persuade users to perform unsafe actions.

Unexpected attachments may contain malicious code, exploit software weaknesses, or lead users to unsafe websites.

Security weaknesses demonstrated:

- Failure to verify whether an attachment was expected.
- Limited understanding of attachment-related risks.
- Trust in messages from unfamiliar or impersonated senders.
- Possible lack of awareness about safe document handling.
- Potential gaps in email filtering or endpoint protection.

Recommended measures:

Employees should verify unexpected attachments with the sender through a separate trusted communication channel. The organization should scan attachments, use suitable security filtering, keep software updated, and deploy endpoint protection.

3. Major Security Weaknesses Identified

The campaign reveals several areas that require improvement.

1. Lack of sender verification

Employees may not check the sender's actual email address or domain. Attackers sometimes use addresses that closely resemble legitimate ones.

2. Lack of link inspection

Users may click links without checking whether the destination matches the expected service.

3. Poor credential protection

Entering credentials on an unexpected page can expose accounts to unauthorized access.

4. Insufficient attachment awareness

Employees may download files without verifying the sender or the business purpose of the attachment.

5. Lack of incident reporting

Employees may not know how to report suspicious emails. Delayed reporting can prevent the security team from responding quickly.

6. Possible technical control gaps

The results also justify reviewing email filtering, identity security, endpoint protection, and access-control policies. Employee actions alone do not explain every weakness.

4. Potential Impact on ABC Technologies Pvt. Ltd.

A successful phishing attack may affect the organization in several ways.

Data loss: Unauthorized access may expose customer details, employee records, financial information, or confidential documents.

Financial loss: Attackers may attempt fraudulent payments or misuse compromised accounts for financial scams.

Malware infection: A harmful attachment may expose a device to malware if it is opened or executed and security controls do not prevent it.

Reputational damage: Customers and business partners may lose confidence if confidential information is exposed.

Operational disruption: Compromised accounts or infected systems may require investigation, recovery, and temporary service restrictions.

Legal and compliance concerns: Exposure of protected information may create notification, contractual, or regulatory obligations, depending on the circumstances.

A simulated phishing result does not prove that a real compromise occurred. The organization should investigate actual system logs and activity before determining the impact.

5. Employee Awareness Programs

ABC Technologies should implement a structured employee awareness program.

A. Basic phishing-awareness training

Employees should learn to identify:

- Suspicious sender addresses.
- Misspelled or misleading domains.
- Unexpected links and attachments.
- Unusual requests for passwords or confidential information.
- Messages creating unnecessary urgency.
- Requests for payments or changes to bank details.
- Unexpected login pages.

Training should use simple language and practical examples.

B. Regular phishing simulations

The organization should conduct authorized simulations at suitable intervals. Different scenarios can help employees learn to recognize various types of social engineering.

After each exercise, employees should receive supportive feedback explaining the warning signs and the correct response.

C. Role-based training

Different departments face different risks.

- Finance employees: Training on invoice fraud and payment-change requests.
- Human resources employees: Training on suspicious résumés and employee documents.
- IT employees: Training on credential theft and administrative-access risks.
- Managers: Training on impersonation and fraudulent approval requests.

D. Easy reporting process

Employees should have a simple way to report suspicious emails, such as a reporting button or a dedicated security email address.

The organization should encourage employees to report mistakes quickly. Prompt reporting allows the security team to investigate and protect other users.

E. Continuous learning

Short awareness sessions, regular reminders, onboarding training, and practical exercises should be provided throughout the year.

6. Email Security Controls

Employee awareness should be supported by technical controls.

A. Email filtering

Secure email gateways and cloud email-protection systems can detect spam, suspicious messages, known malicious links, and potentially harmful attachments.

B. SPF, DKIM, and DMARC

These email authentication mechanisms help organizations reduce certain forms of email-domain spoofing.

- SPF: Identifies servers authorized to send email for a domain.
- DKIM: Uses a digital signature to help verify message authenticity and integrity.
- DMARC: Defines how receiving systems should handle messages that fail specified authentication checks and provides reporting.

These controls should be configured correctly and monitored regularly.

C. Multifactor authentication

Multifactor authentication adds another verification step beyond a password. It reduces the risk of account compromise when a password is stolen, although it does not prevent every phishing attack.

Where possible, the organization should use phishing-resistant authentication methods.

D. Attachment scanning

Email systems should scan attachments for known threats and use additional analysis for suspicious files where available.

E. Endpoint protection

Company devices should have updated security software, appropriate access restrictions, and timely operating-system and application updates.

F. Login monitoring

The security team should monitor unusual sign-ins, suspicious account activity, unexpected mailbox rules, and abnormal email-sending behavior.

7. Organizational Policies

ABC Technologies should establish clear policies covering email usage, password security, attachment handling, and incident reporting.

Employees should be instructed to verify sensitive requests through a separate trusted channel. For example, a request to change supplier bank details should be confirmed using an independently verified contact method.

The organization should also:

1. Enforce suitable password and multifactor authentication requirements.
2. Provide clear procedures for reporting phishing.
3. Define responsibilities for employees and IT staff.
4. Maintain an incident-response plan.
5. Protect employee simulation data and restrict access to results.
6. Review policies periodically.
7. Provide security training to new employees.
8. Maintain appropriate access controls for sensitive information.

Phishing exercises should be used to improve security rather than embarrass employees. Simulation results should be handled fairly and confidentially.

8. Response to a Suspected Phishing Incident

If an employee suspects that they have interacted with a real phishing message, the following steps should be followed.

Step 1: Report the email immediately to the security team.

Step 2: If credentials were entered, contact IT so the affected credentials and active sessions can be secured.

Step 3: If an attachment was opened or executed, follow the organization's incident-response instructions. The security team may need to isolate the device and investigate it.

Step 4: Review account activity and system logs to identify unauthorized access.

Step 5: Search for similar messages and block confirmed malicious indicators where appropriate.

Step 6: Inform relevant stakeholders according to the organization's response procedures.

Step 7: Review the incident and improve training and technical controls.

9. Measuring Improvement

The organization should compare campaign results over time using meaningful metrics.

These include the click rate, credential-submission rate, attachment interaction rate, reporting rate, and time taken to report suspicious messages.

The results should be compared across similar campaigns. A lower click rate is useful, but an increase in timely reporting is also an important indicator of improved awareness.

10. Conclusion

The GoPhish report indicates that phishing is a significant security concern for ABC Technologies Pvt. Ltd. The 40% click rate, 20% credential-submission rate, and attachment downloads demonstrate the need for improved employee awareness and stronger technical controls.

The organization should provide regular training, conduct authorized phishing simulations, implement email filtering, configure email authentication, enforce multifactor authentication, and establish clear reporting policies.

By combining employee awareness with effective security technology and continuous monitoring, ABC Technologies can reduce the likelihood and impact of successful social-engineering attacks.

QUESTION 3: DNS ZONE TRANSFER (AXFR) ANALYSIS

1. Introduction

DNS stands for Domain Name System. It translates domain names into IP addresses and helps users access websites, email servers, and other network services.

The Dig utility is a command-line tool used to query DNS servers and examine DNS records.

In this case, a DNS assessment report generated using Dig shows that the organization's DNS server permits a successful DNS Zone Transfer, also called AXFR. The transfer exposes internal hostnames, mail servers, and DNS records.

A zone transfer is a legitimate DNS function used to synchronize DNS data between authorized DNS servers. However, if an unauthorized requester can transfer the zone, sensitive infrastructure information may be disclosed.

2. Information Exposed by the DNS Zone Transfer

A. Internal hostnames

Hostnames identify systems and services within an organization's network. Examples may include application servers, development systems, backup servers, and administration systems.

If internal hostnames are exposed, an attacker may gain a better understanding of the organization's infrastructure.

B. Mail server information

DNS records such as MX records identify the mail servers responsible for receiving email for a domain.

Other associated records may reveal hostnames and IP addresses connected with the email infrastructure.

This information may help an attacker understand the organization's email environment and prepare targeted social-engineering attempts.

C. DNS records

DNS zones may contain several types of records.

- A record: Maps a hostname to an IPv4 address.
- AAAA record: Maps a hostname to an IPv6 address.
- CNAME record: Defines an alias for another hostname.
- MX record: Identifies mail servers for a domain.
- TXT record: Stores text information used for different purposes, including some email-security configurations.
- NS record: Identifies authoritative name servers for a DNS zone.

Collectively, these records may reveal information about the organization's network and services.

D. Infrastructure structure

The combination of hostnames, aliases, and service records may help an observer understand relationships between systems.

For example, records may indicate which systems are associated with applications, email, backups, or administrative functions.

Not every DNS record is confidential. The concern is that a complete zone transfer may expose internal or operational details to people who are not authorized to access them.

3. Security Implications of an Unauthorized Zone Transfer

A. Information disclosure

The primary risk is the disclosure of DNS information that was not intended for public access. This information may make it easier to understand the organization's infrastructure.

B. Improved reconnaissance

An attacker may use the exposed records to identify systems that appear important and plan further unauthorized reconnaissance.

C. Identification of sensitive systems

Hostnames suggesting administration, development, database, or backup functions may attract unwanted attention.

D. Targeted social engineering

Knowledge of internal names, mail systems, or organizational terminology may help an attacker create more convincing fraudulent messages.

E. Discovery of outdated records

Old DNS records may reveal forgotten or retired systems. These records should be reviewed because an outdated record does not necessarily mean that the corresponding system is still active.

4. Example of a Potential Attack Scenario

An unauthorized person obtains DNS zone data and reviews the exposed hostnames, mail records, and other entries. The person uses this information to understand the organization's infrastructure and identify potentially important systems.

The person may then attempt further unauthorized reconnaissance or create targeted phishing messages using familiar organizational terminology.

If another weakness exists, such as outdated software or weak authentication, the attacker may attempt to exploit that separate weakness.

However, a successful zone transfer does not itself prove that the exposed systems are vulnerable or that an attacker has gained access to them.

5. Recommended Security Measures

A. Restrict DNS Zone Transfers

The DNS administrator should configure the server to permit AXFR requests only from explicitly authorized secondary DNS servers.

Requests from unauthorized systems should be denied.

B. Use Appropriate Authentication

Where supported, TSIG can authenticate DNS zone-transfer communication between authorized servers.

Shared secrets should be protected and managed securely.

Authentication should be used alongside appropriate network access restrictions.

C. Separate Internal and External DNS

Organizations should consider maintaining separate internal and external DNS views or zones when appropriate.

Only records required for public services should be exposed externally. Internal hostnames and records should remain in the appropriate internal DNS environment.

D. Remove Unnecessary DNS Records

Administrators should regularly review DNS zones and remove outdated or unnecessary records after confirming that they are no longer required.

An accurate DNS inventory helps reduce accidental information disclosure.

E. Update DNS Software

DNS software should be kept supported and updated. Administrators should disable unnecessary features and follow secure configuration guidelines.

F. Monitor DNS Activity

The organization should monitor DNS logs for unexpected zone-transfer requests, repeated denied requests, and unusual DNS activity.

Alerts should be configured for suspicious events, and logs should be protected against unauthorized modification.

G. Protect DNS Administration

DNS administration should use strong authentication, least privilege, and restricted management access.

Changes to DNS records and configurations should follow an approved change-management process.

H. Regular Security Assessment

The organization should conduct authorized DNS reviews to verify that zone transfers are restricted correctly and that legitimate secondary servers can still synchronize.

6. DNS Security Checklist

The organization should verify the following:

1. Identify all authoritative DNS servers and zones.
2. List the authorized secondary DNS servers.
3. Restrict AXFR to approved servers.
4. Confirm that unauthorized transfer requests are denied.
5. Verify that legitimate zone synchronization still works.
6. Review internal and external DNS records.
7. Remove stale or unnecessary records.
8. Update DNS software.
9. Monitor DNS logs and configuration changes.

10. Maintain secure backups of DNS configuration and zone data.

7. Conclusion

The DNS assessment reveals that the organization's DNS server permits a successful AXFR zone transfer, exposing internal hostnames, mail servers, and DNS records.

This information may help an attacker perform reconnaissance, identify important systems, and prepare targeted social-engineering attempts.

The organization should restrict zone transfers to authorized secondary servers, use suitable authentication, separate internal and external DNS where appropriate, remove outdated records, and monitor DNS activity.

Regular configuration reviews and authorized testing will help ensure that DNS information is available to legitimate systems without unnecessary disclosure.

OVERALL SUMMARY

The three security assessments demonstrate the importance of identifying and reducing cybersecurity risks. The Nmap scan helps identify open ports and running services. The GoPhish campaign evaluates employee responses to phishing attempts. The DNS zone-transfer assessment identifies possible information disclosure through DNS configuration.

Each finding should be interpreted carefully. An open port does not automatically prove a vulnerability, a simulated phishing interaction does not prove that a system was compromised, and exposed DNS information does not automatically provide access to a network.

Organizations should follow a defense-in-depth approach that combines secure configuration, regular patching, strong authentication, least privilege, employee training, monitoring, and incident response.

All ethical-hacking activities must be performed with proper authorization and within the approved assessment scope.